

LAB: FILE PATH TRAVERSAL

TRAVERSAL SEQUENCES STRIPPED NON-RECURSIVELY

LUIS EMMANUEL ARONIA SILVA

Parcial 1 – Fundamentos de la Ciberseguridad

**UNIVERSIDAD POLITECNICA DE SAN LUIS
POTOSI**

Mtro. Servando López Contreras

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Ut enim ad minim veniam, quis nostrud exercitation ullamco laboris nisi ut aliquip ex ea commodo consequat. Duis aute irure dolor in reprehenderit in voluptate velit esse cillum dolore eu fugiat nulla pariatur. Excepteur sint occaecat cupidatat non proident, sunt in culpa qui officia deserunt mollit anim id est laborum.

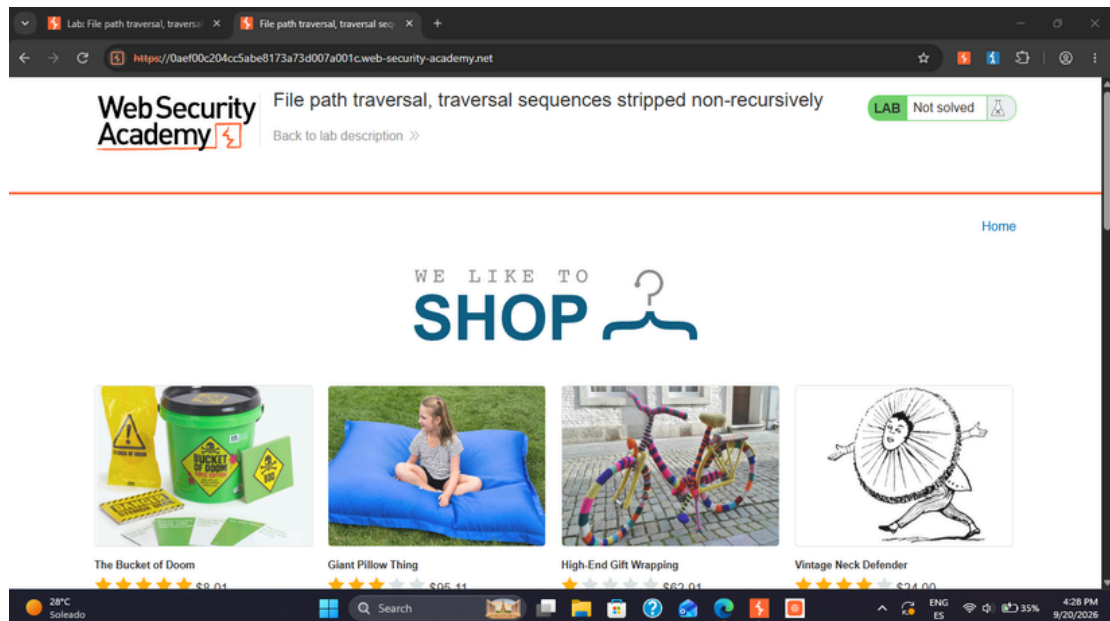
Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Ut enim ad minim veniam, quis nostrud exercitation ullamco laboris nisi ut aliquip ex ea commodo consequat. Duis aute irure dolor in reprehenderit in voluptate velit esse cillum dolore eu fugiat nulla pariatur. Excepteur sint occaecat cupidatat non proident, sunt in culpa qui officia deserunt mollit anim id est laborum.

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Ut enim ad minim veniam, quis nostrud exercitation ullamco laboris nisi ut aliquip ex ea commodo consequat. Duis aute irure dolor in reprehenderit in voluptate velit esse cillum dolore eu fugiat nulla pariatur. Excepteur sint occaecat cupidatat non proident, sunt in culpa qui officia deserunt mollit anim id est laborum.

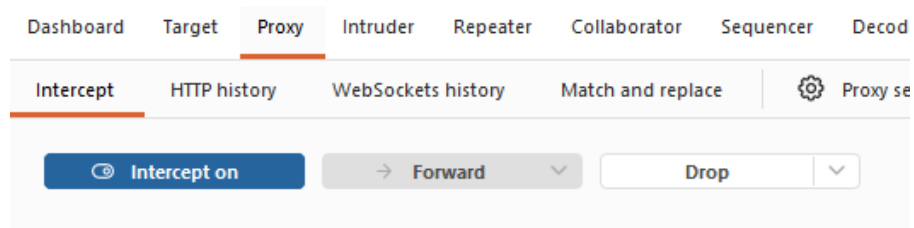
GUIA DOCUMENTADA

Para comenzar este laboratorio hay que abrir el navegador que viene en Burp suite, para lo cual solo tenemos que iniciar la aplicacion, despues entrar a la pestaña de proxy, y en esa pantalla entrar a Intercept, ahi veremos el boton para abrir el navegador, una vez dentro solo hay que entrar con el link oficial del laboratorio:

- <https://portswigger.net/web-security/file-path-traversal/lab-sequences-stripped-non-recursively>



Ahora regresando a Burp Suite, en la pestaña en la que estabamos hay que fijarnos en el Boton de Intercept y dando click en el, asegurandonos de que diga Intercept On

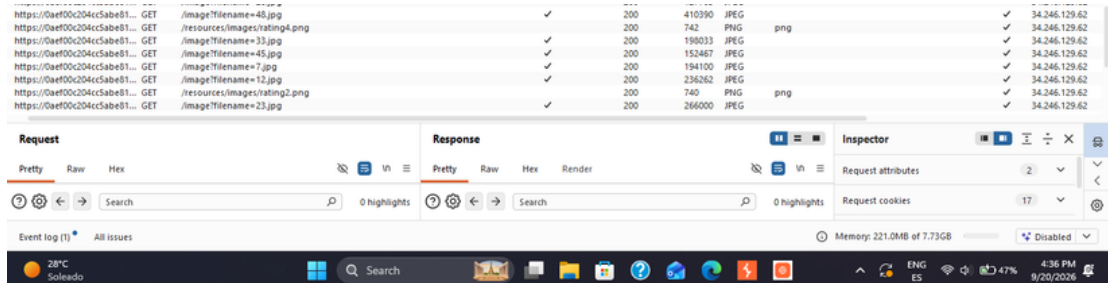


Una vez esa parte este en On hay que regresar al navegador y hacer click en cualquier producto, esto para capturar la peticion de la imagen desde Burp Suite

GUIA DOCUMENTADA

Ahora al haber hecho click en cualquier imagen del producto deberiamos encontrar algunas peticiones que tengan este estilo:

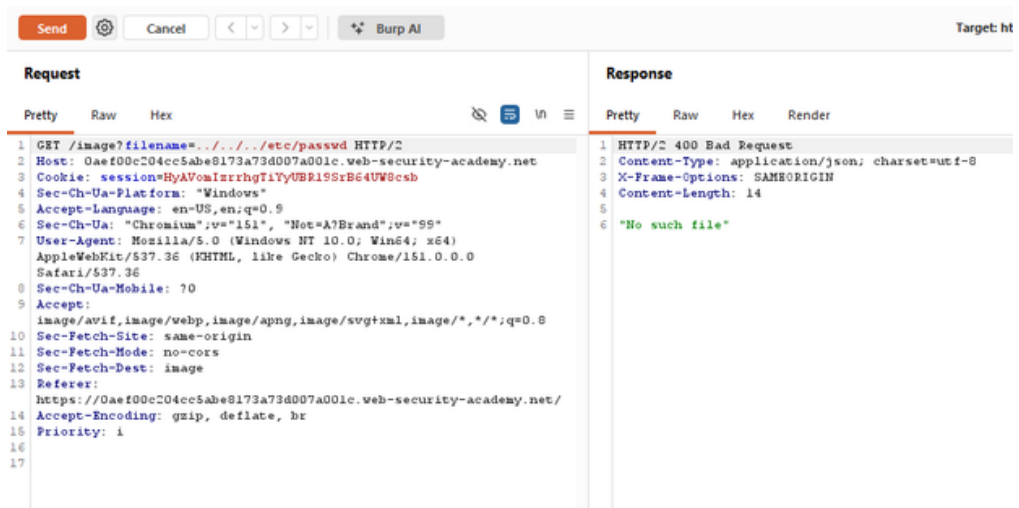
- GET /image?filename=XX.jpg



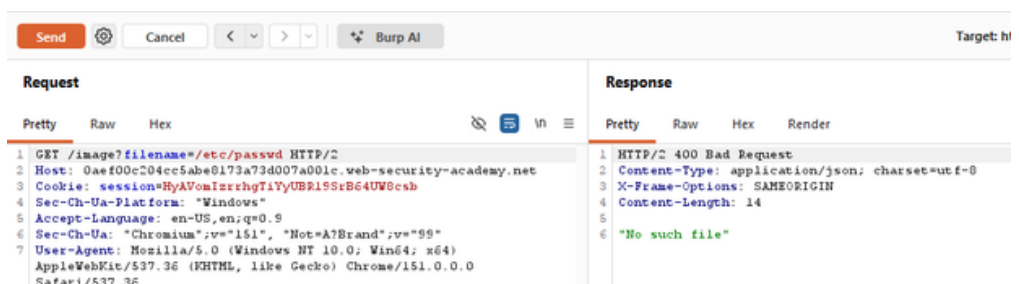
Una vez encontrandolas se envia al Repeater, con click derecho y Send to Repeater.

Ahora entramos a ese menu, una vez ahi primero vamos a probar los payloads anteriores en el valor del filename, veremos como es que estos fallaran

- ../../../../etc/passwd



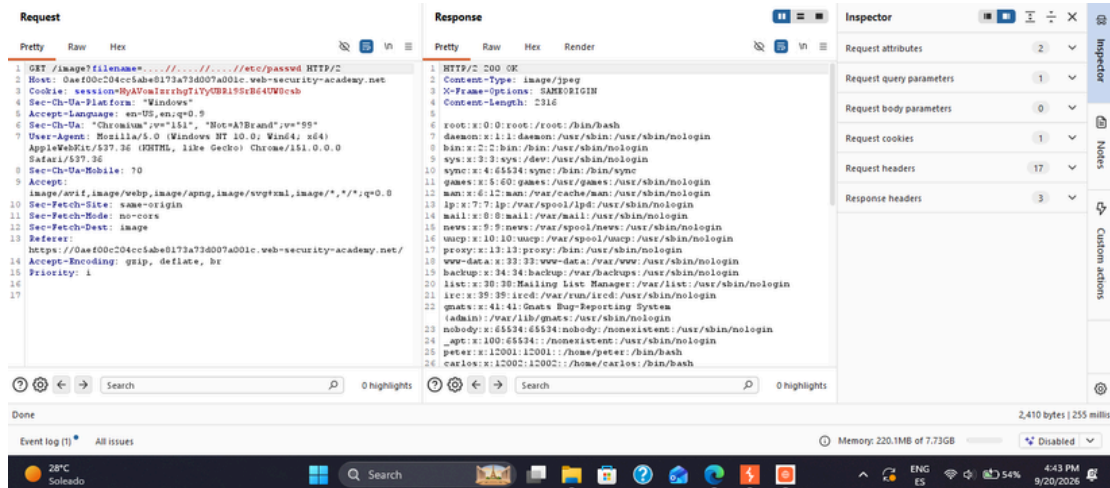
- /etc/passwd



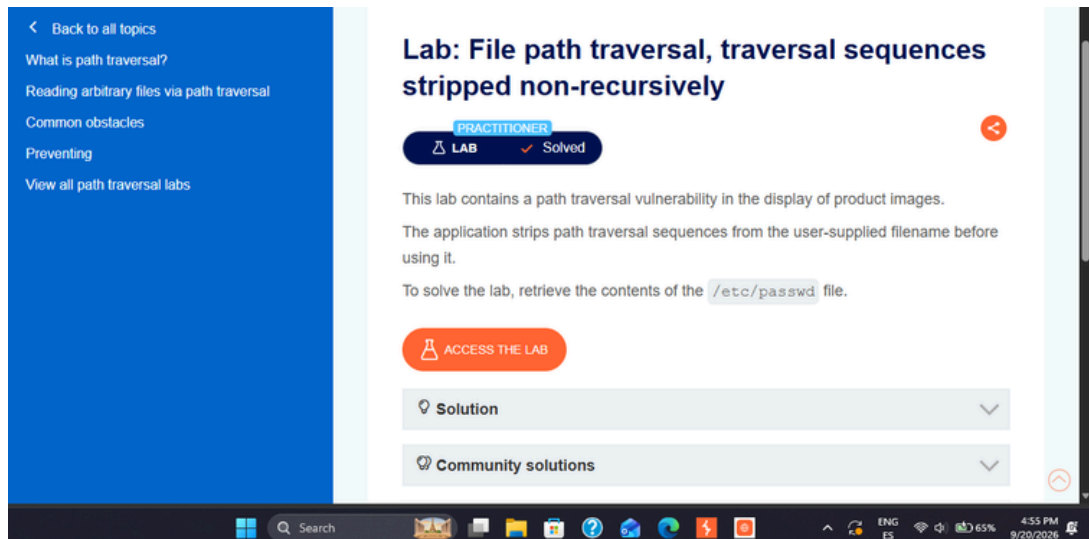
GUIA DOCUMENTADA

Habiendo probado los payloads de anteriores laboratorios y viendo que no funcionan ahora es el turno del correcto, que es el siguiente:

-//....//....//etc/passwd



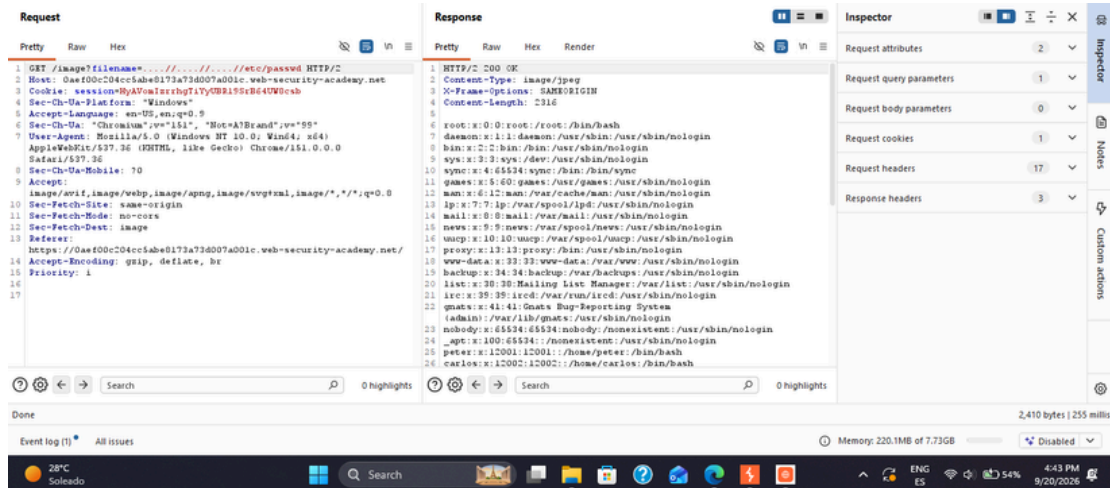
Se obtuvo ese resultado, ahora tenemos acceso al archivo **/etc/passwd**
El laboratorio fue concluido



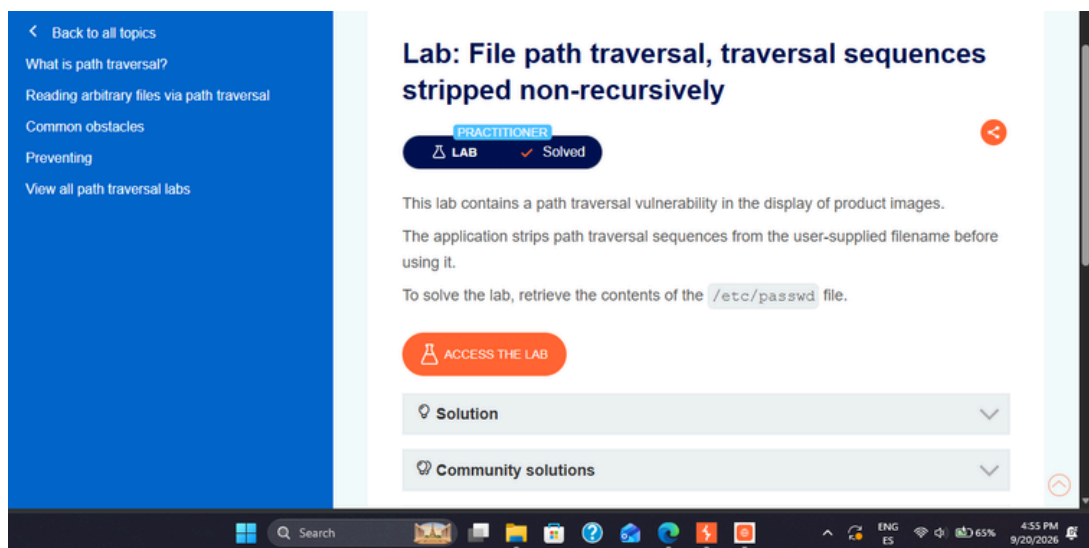
GUIA DOCUMENTADA

Habiendo probado los payloads de anteriores laboratorios y viendo que no funcionan ahora es el turno del correcto, que es el siguiente:

-//....//....//etc/passwd



Se obtuvo ese resultado, ahora tenemos acceso al archivo **/etc/passwd**
El laboratorio fue concluido



Pudimos ver como es que la aplicación elimina las secuencias **../** del nombre del archivo una sola vez (no recursivamente).

Cuando enviamos:

....//....//....//etc/passwd

El servidor elimina las secuencias **../** internas, y el valor se convierte en:

../../etc/passwd

De esta forma, después de la limpieza, queda un payload de Path Traversal válido que sí funciona.